Podstawy Web

Spis treści

Wstęp 3
Przygotowanie środowiska 4
Uruchamianie maszyn 5
Połączenie OpenVPN 6
Niezaliczone zadanie 7
Uruchamianie i przygotowanie Burp 8
Legenda 10
Teoria 11
Burp Suite - wersja darmowa a płatna 12
Alternatywy dla Burp Suite 14
Narzędzia developerskie w przeglądarce 16
OWASP ZAP - darmowa alternatywa 17
Podsumowanie 18
Zadania 19
Zadanie 3.1: Burp Suite HTTP History 20
Zadanie 3.2: Burp Suite Intercept 23
Zadanie 3.3: Burp Suite Repeater 27
Zadanie 3.4: Burp Suite Intruder 32
Zadanie 3.5: Burp Suite Decoder 37
Referencje 40

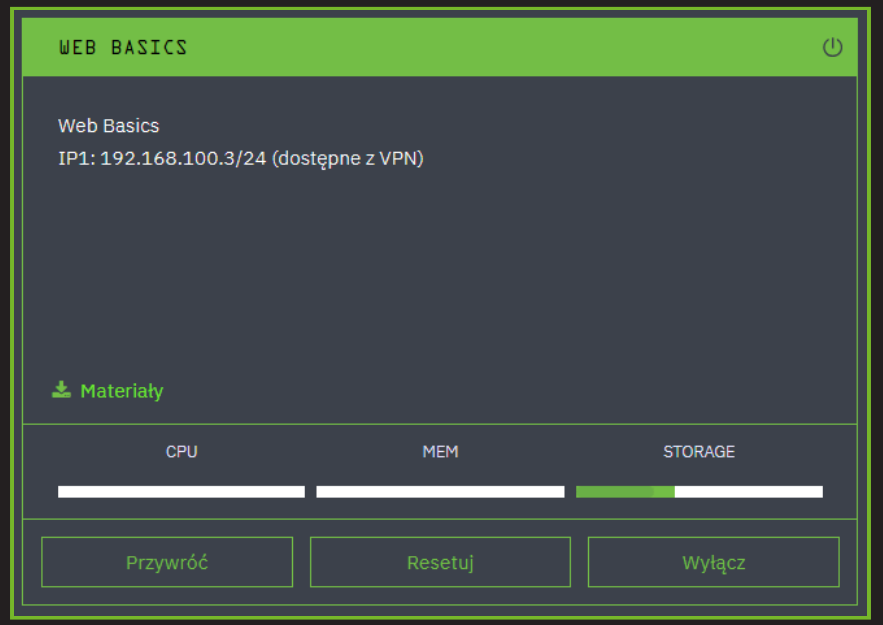
Wstęp

Burp Suite to kompleksowe narzędzie do testowania bezpieczeństwa aplikacji webowych. Umożliwia przeprowadzanie analiz i testów w celu wykrywania podatności, takich jak **SQL injection**, **XSS** czy **błędy konfiguracji**. Burp Suite oferuje funkcje **przechwytywania** i **modyfikowania** ruchu HTTP/HTTPS, automatyzacji testów, analizy danych oraz raportowania wyników. Jest szeroko stosowane przez specjalistów ds. bezpieczeństwa i testerów penetracyjnych do oceny i poprawy bezpieczeństwa aplikacji internetowych.

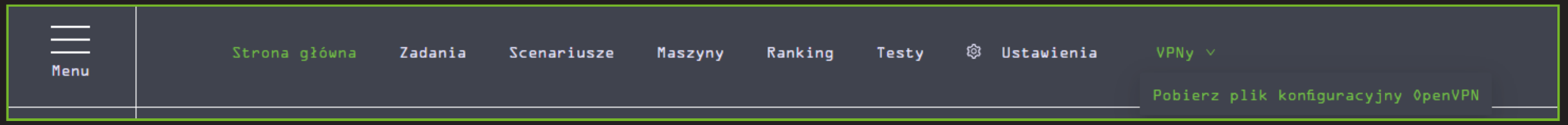
Przygotowanie środowiska

Uruchamianie maszyn

Przed rozpoczęciem upewnij się, że maszyna Web Basics jest włączona.
Jeżeli coś się zepsuje, w każdej chwili możesz ją przywrócić do stanu początkowego.



Połączenie OpenVPN



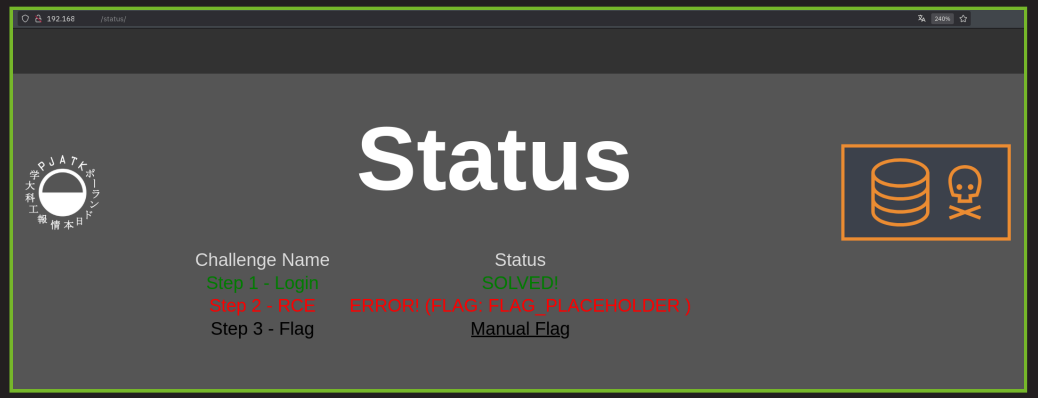
Połączenie OpenVPN jest niezbędne do rozwiązania zadań.
Aby połączyć się z siecią VPN, należy pobrać plik konfiguracyjny OpenVPN z rozwijanego menu „**VPNy**” na stronie głównej.
Następnie należy wykonać komendę:

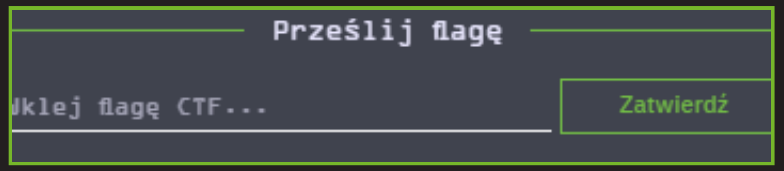
```
sudo openvpn /sciezka/do/pliku.ovpn
```

Komendy, będące częścią zadań, należy rozwiązywać w osobnej karcie/oknie terminala!

Niezaliczone zadanie

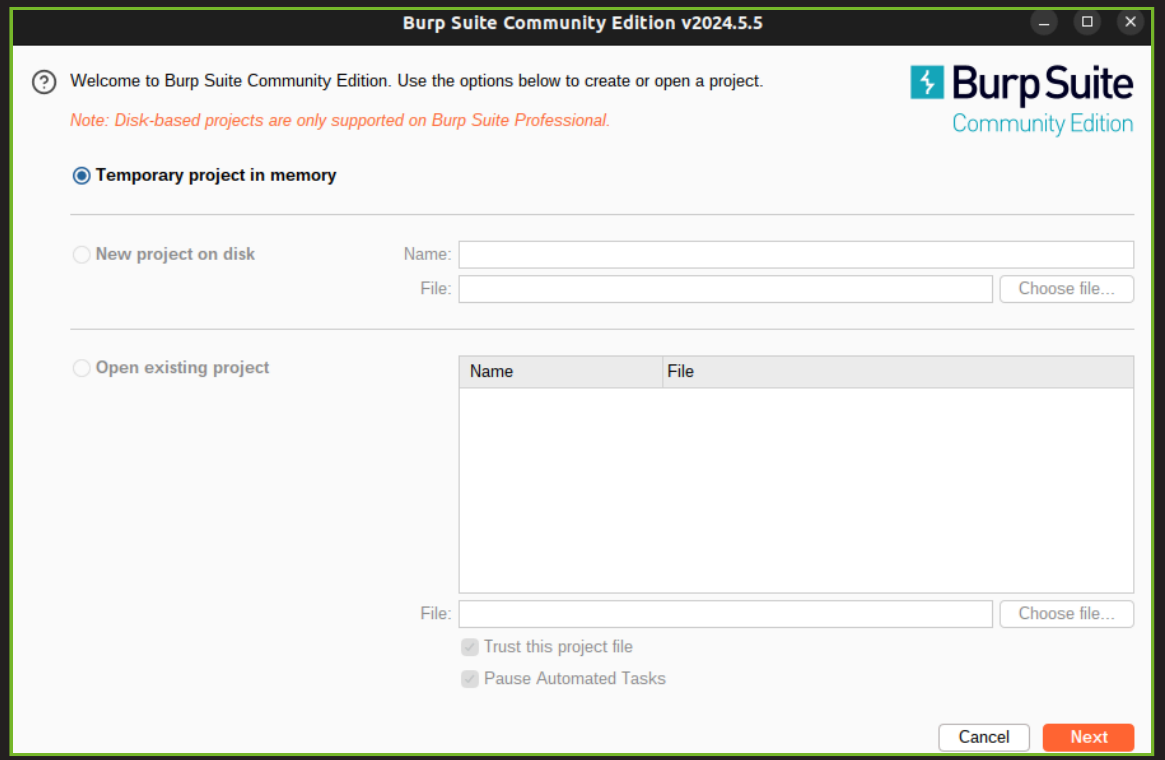
Niektóre rozwiązane zadania powinny zaliczać się w systemie automatycznie. Jeśli jednak pojawi się problem i któreś z zadań rozwiążesz prawidłowo, a nadal będzie ono widnieć jako nierozwiązane, możesz odwiedzić podstronę `/status` na maszynie zadaniowej. Tam widnieć będzie flaga, którą możesz wkleić w swoim panelu i zaliczyć zadanie „ręcznie”.

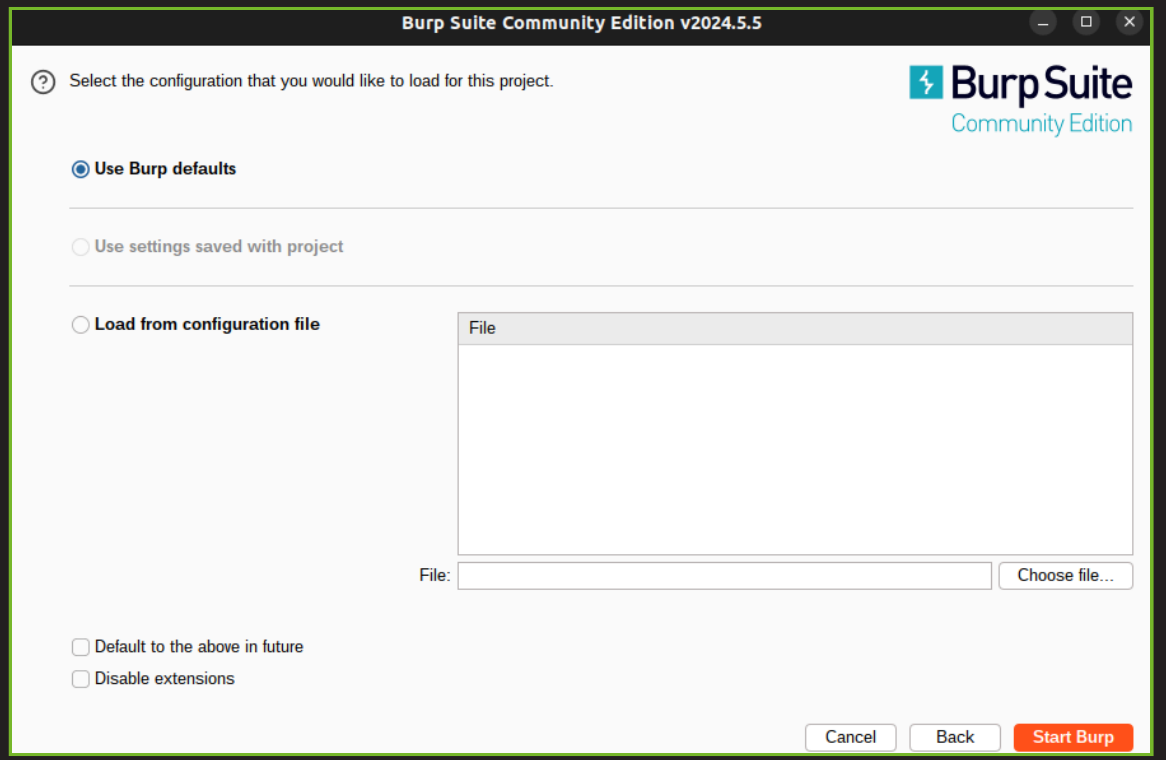




Uruchamianie i przygotowanie Burp

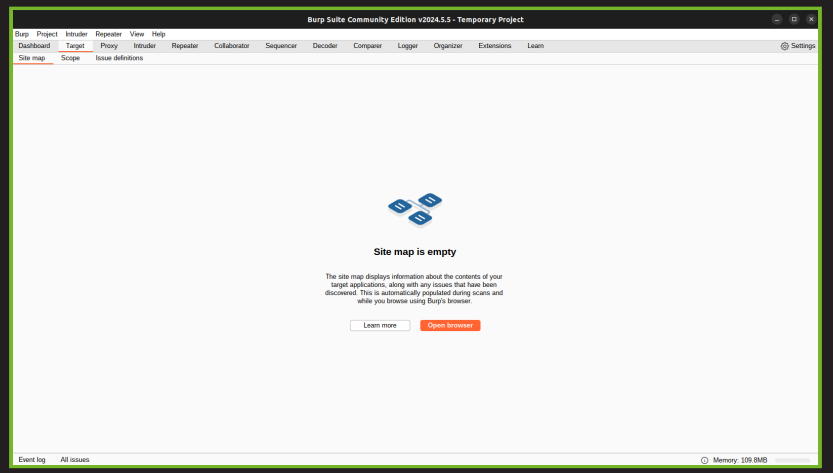
Uruchom program Burp i wybierz kolejno opcje *Temporary project in memory* oraz *Use Burp defaults*.





Uruchamianie i przygotowanie Burp

Aby śledzić nasze zapytania, mamy dwie możliwości. Dziś użyjemy przeglądarki wbudowanej w Burp. Możemy też jednak ustawić proxy w naszej ulubionej przeglądarce i przekierować cały ruch przez Burpa. Instrukcja, jak to zrobić, znajduje się w referencjach.
Aby uruchomić wbudowaną przeglądarkę przejdź na kartę *Target* i kliknij *Open browser*.



Legenda

`cat /etc/passwd` - komendę należy wykonać na maszynie Kali
`cat /etc/passwd` - komendę należy wykonać na maszynie Ćwiczenia
`cat /etc/passwd` - komendę należy wykonać na maszynie Pentest

Teoria

Burp Suite - wersja darmowa a płatna

Burp Suite to jedno z najpopularniejszych narzędzi do analizy ruchu HTTP, szczególnie wykorzystywane przez pentesterów i badaczy zabezpieczeń. Dostępne są dwie wersje: `Community` (darmowa) oraz `Professional` (płatna).
Dla osób zajmujących się testami penetracyjnymi na szeroką skalę wersja profesjonalna może być niezbędna, ale do podstawowej analizy HTTP darmowa wersja Burpa również może być wystarczająca.

Burp Suite - wersja darmowa a płatna

Burp Suite Community Edition (darmowa):

- Podstawowe funkcje proxy umożliwiające przechwytywanie i edytowanie ruchu HTTP i HTTPS.
- Ręczna analiza i manipulacja danymi.
- Brak zaawansowanych funkcji automatycznej analizy i exploitacji.
- Ograniczone moduły i brak narzędzi dedykowanych do automatycznego testowania podatności.

Burp Suite Professional (płatna):

- Automatyczny skaner podatności webowych.
- Zaawansowane narzędzia do analizowania aplikacji webowych.
- Obsługa rozszerzeń i skryptów.
- Szybsza analiza i wygodniejszy interfejs.
- Zaawansowane funkcje ataków brute-force i fuzzingu.

Alternatywy dla Burp Suite

Chociaż Burp Suite jest bardzo popularny, istnieje wiele alternatywnych narzędzi do śledzenia ruchu HTTP:

OWASP ZAP (Zed Attack Proxy)

- Najlepsza darmowa alternatywa dla Burpa.
- Zawiera automatyczny skaner podatności.
- Obsługuje skrypty automatyzujące testy.
- Rozbudowane funkcje do analizy ruchu HTTP i WebSocket.

Fiddler

- Bardzo popularny wśród developerów i analityków aplikacji.
- Zaawansowana inspekcja ruchu HTTP/HTTPS.
- Edycja i ponowne wysyłanie zapytań.
- Integracja z systemami Windows i .NET.

Alternatywy dla Burp Suite

Chociaż Burp Suite jest bardzo popularny, istnieje wiele alternatywnych narzędzi do śledzenia ruchu HTTP:

Mitmproxy

- Narzędzie w trybie CLI dla zaawansowanych użytkowników.
- Obsługa skryptów Python do modyfikacji ruchu.
- Przechwytywanie i zmiana treści zapytań oraz odpowiedzi.

Charles Proxy

- Ciekawe narzędzie do analizy ruchu aplikacji mobilnych.
- Możliwość przechwytywania ruchu z iOS i Androida.
- Bardzo przydatny dla testerów aplikacji mobilnych.

Narzędzia developerskie w przeglądarce

Dla podstawowej analizy ruchu HTTP można wykorzystać wbudowane narzędzia developerskie przeglądarek internetowych:

Google Chrome DevTools

- Zakładka „Network” pozwala śledzić zapytania i odpowiedzi HTTP.
- Możliwość analizowania nagłówków i ładunku zapytań.
- Opcja throttlingu pozwalająca na symulowanie różnych warunków sieciowych.

Firefox Developer Tools

- Podobne funkcje do Chrome DevTools.
- Opcja modyfikowania zapytań i podglądu cache.

Edge Developer Tools

- Zintegrowane narzędzia do analizy ruchu w przeglądarce Microsoft Edge.

OWASP ZAP - darmowa alternatywa

OWASP ZAP to jedno z najlepszych darmowych narzędzi do testów aplikacji webowych. Jest to narzędzie rozwijane przez OWASP (Open Web Application Security Project), które oferuje:

- Automatyczne i ręczne skanowanie podatności aplikacji webowych.
- Przechwytywanie i edytowanie ruchu HTTP.
- Integrację z CI/CD dla automatyzacji testów.
- Obsługę skryptów w JavaScript do automatycznej analizy ruchu.

W przeciwieństwie do Burp Suite, OWASP ZAP jest w pełni darmowy i może być dobrym wyborem dla osób, które nie chcą inwestować w płatne narzędzia.

Podsumowanie

Analiza ruchu HTTP jest kluczowym elementem testów penetracyjnych i analizy zabezpieczeń aplikacji webowych. Burp Suite pozostaje najpopularniejszym narzędziem, jednak istnieje wiele alternatyw, takich jak OWASP ZAP, Fiddler czy Mitmproxy. Dla podstawowej analizy ruchu można wykorzystać narzędzia wbudowane w przeglądarki. Odpowiednia konfiguracja proxy pozwala skutecznie przechwytywać i modyfikować ruch, co jest kluczowe w pentestach i analizie aplikacji.

Zadania

Zadanie 3.1: Burp Suite HTTP History

Zakładka **HTTP History** w Burp Suite rejestruje wszystkie żądania i odpowiedzi HTTP przechodzące przez proxy, co pozwala na ich szczegółową analizę. Umożliwia przeglądanie nagłówków, treści żądań i odpowiedzi, a także filtrowanie i sortowanie danych według różnych kryteriów. Dzięki opcji edycji i ponownego przesyłania żądań, testerzy mogą łatwo badać reakcje serwera na różne scenariusze. Sesje można zapisywać i wczytywać do dalszej analizy. To narzędzie jest kluczowe dla testerów bezpieczeństwa w identyfikowaniu podatności aplikacji.

Zadanie 3.1: Burp Suite HTTP History

Celem zadania jest zapoznanie studenta z historią HTTP w programie Burp Suite.

1. Wejdź na stronę http://192.168.100.3.

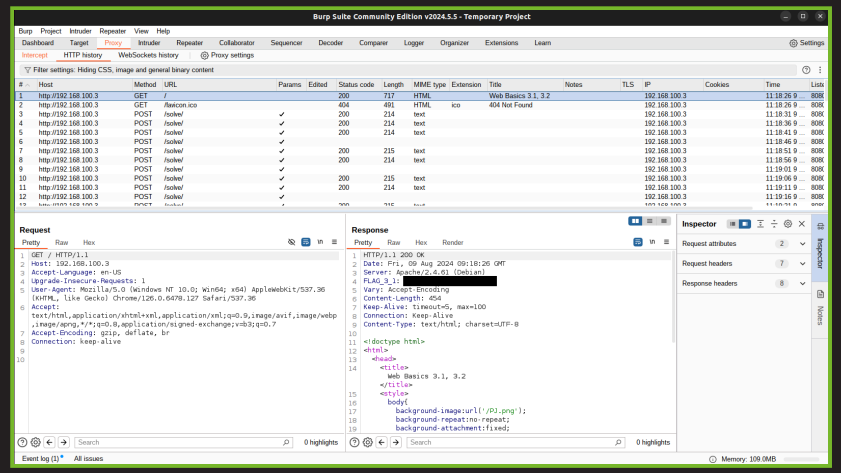


Zadanie 3.1: Burp Suite HTTP History

Celem zadania jest zapoznanie studenta z historią HTTP w programie Burp Suite.

2. W historii zapytań (Request) HTTP w Burp należy odnaleźć zapytanie na stronę główną (/) i odczytać flagę zapisaną w jednym z nagłówków odpowiedzi (Response) HTTP.

Flagę odczytaną z nagłówka FLAG_3_1 należy wkleić w formularzu na platformie.





Zadanie 3.2: Burp Suite Intercept

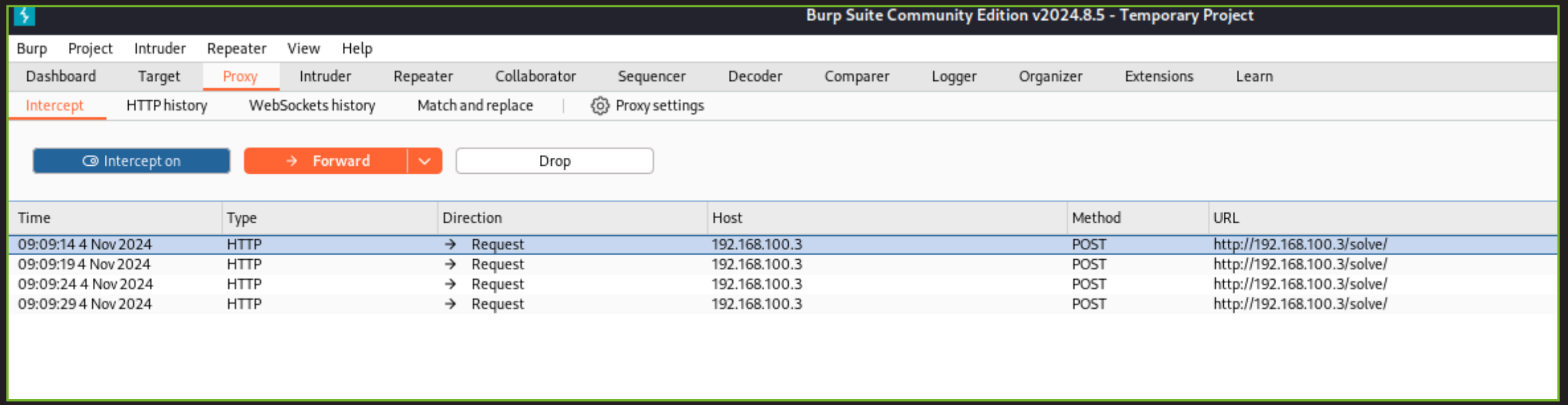
Zakładka **Proxy -> Intercept** w Burp Suite pozwala na przechwytywanie i modyfikowanie żądań i odpowiedzi HTTP w czasie rzeczywistym. Użytkownik może zatrzymać ruch, wprowadzać zmiany w treści żądań lub odpowiedzi, a następnie wysłać je dalej do serwera lub przeglądarki. Funkcja ta jest kluczowa do testowania zabezpieczeń, umożliwiając symulację ataków oraz badanie reakcji aplikacji na nietypowe dane. Intercept może być włączany i wyłączany w dowolnym momencie, co daje pełną kontrolę nad analizowanym ruchem. To narzędzie jest niezbędne do manualnego testowania i eksploracji aplikacji webowych.

Zadanie 3.2: Burp Suite Intercept

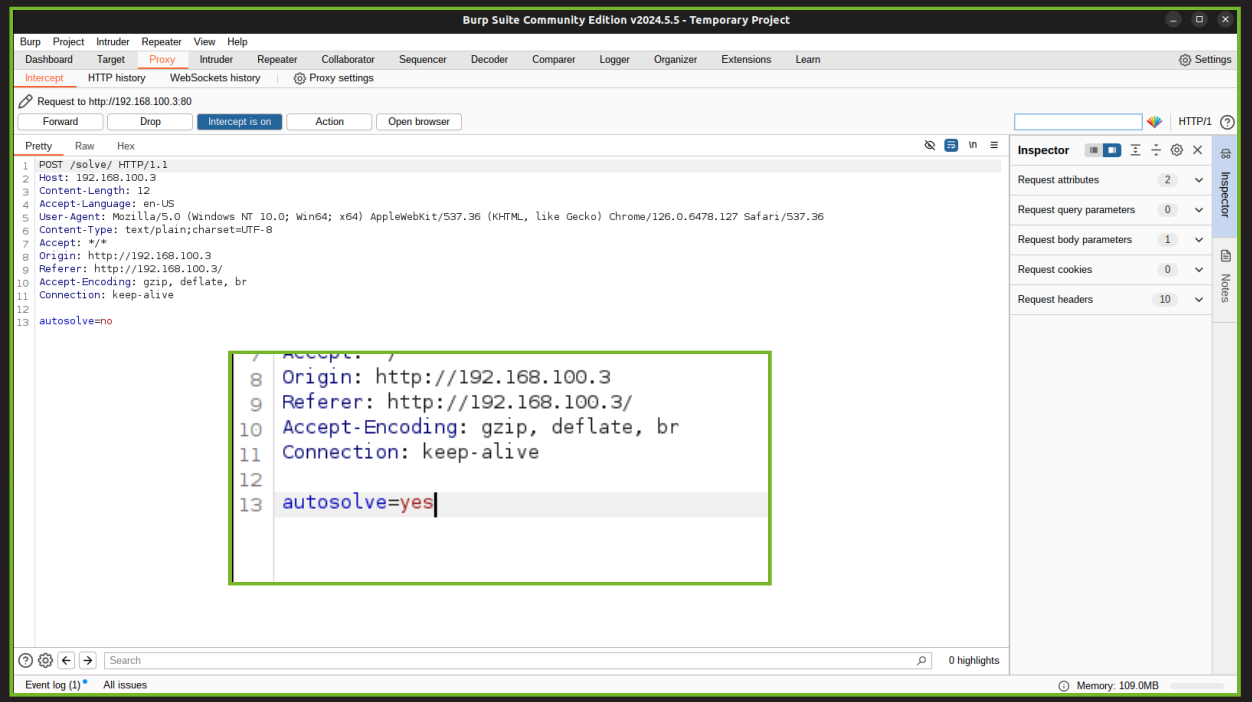
Celem zadania jest zapoznanie studenta z mechanizmem Intercept w programie Burp Suite.

1. Mając otwartą stronę http://192.168.100.3 we wbudowanej przeglądarce Burp, należy uruchomić intercept i przechwycić zapytanie do „/solve/”. Wybierz opcję „send to Intruder”. W przechwyconym zapytaniu należy zmodyfikować parametr „autosolve” z „no” na „yes”.
2. Mechanizm Intercept czasami utrudnia dalsze kroki, więc można rozważyć wyłączenie go, kiedy nie jest potrzebny. Pamiętaj jednak o ponownym włączeniu, kiedy znów będzie nam niezbędny.

Zadanie 3.2: Burp Suite Intercept



Zadanie 3.2: Burp Suite Intercept







Zadanie 3.3: Burp Suite Repeater

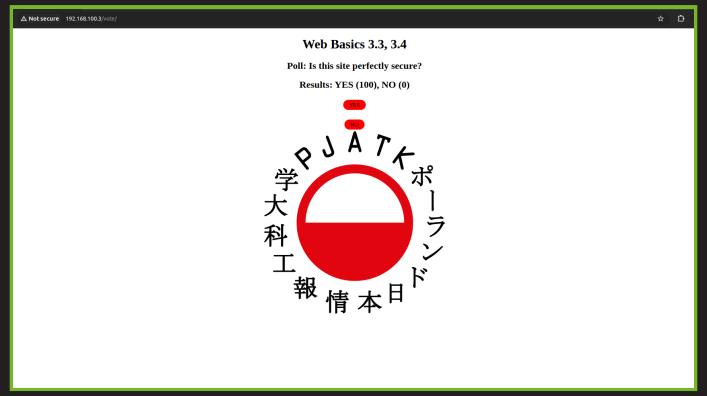
Zakładka **Repeater** w Burp Suite umożliwia testerom ręczne modyfikowanie oraz ponowne wysyłanie żądań HTTP do serwera. Użytkownicy mogą edytować nagłówki, parametry i treść żądań, a następnie obserwować odpowiedzi serwera. Jest to przydatne narzędzie do testowania różnych scenariuszy, takich jak sprawdzanie podatności na różne ataki. Repeater pozwala na szybkie iteracje oraz analizę, co ułatwia zrozumienie działania aplikacji i identyfikację problemów bezpieczeństwa. To narzędzie jest kluczowe dla dokładnego testowania aplikacji webowych i diagnozowania zachowań serwera.

Uważaj na zastosowanie odpowiedniej metody (przeważnie POST lub GET). Możesz ją zmienić w pierwszej linijce payloadu.

Zadanie 3.3: Burp Suite Repeater

Celem zadania jest zapoznanie studenta z funkcjonalnością Repeater w programie Burp Suite.

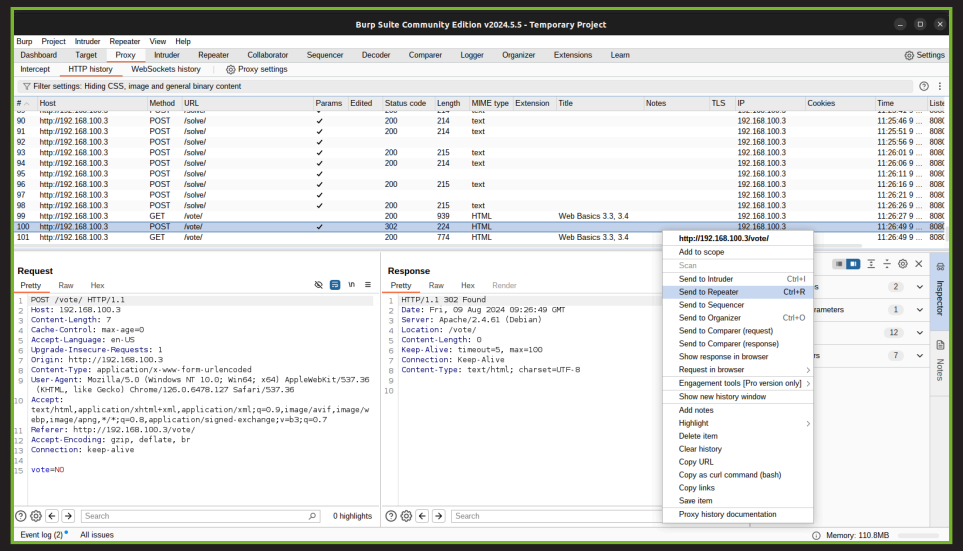
1. Na stronie http://192.168.100.3/vote/ znajduje się ankieta, w której można tylko raz zagłosować (czy strona jest dobrze zabezpieczona, czy nie).



Zadanie 3.3: Burp Suite Repeater

Celem zadania jest zapoznanie studenta z funkcjonalnością Repeater w programie Burp Suite.

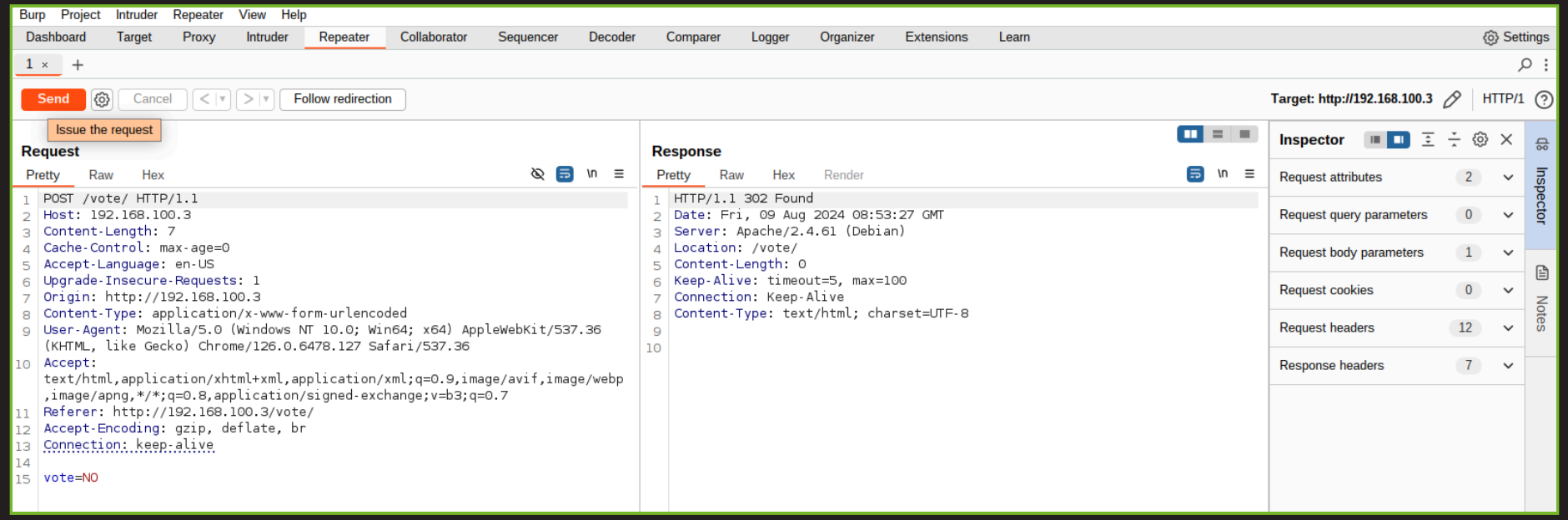
2. Zagłosuj, że strona jest słabo zabezpieczona.
3. W historii HTTP w Burp odnajdź zapytanie, w którym zagłosowałeś na „NIE”, kliknij PPM, wybierz „Send to Repeater”



Zadanie 3.3: Burp Suite Repeater

Celem zadania jest zapoznanie studenta z funkcjonalnością Repeater w programie Burp Suite.

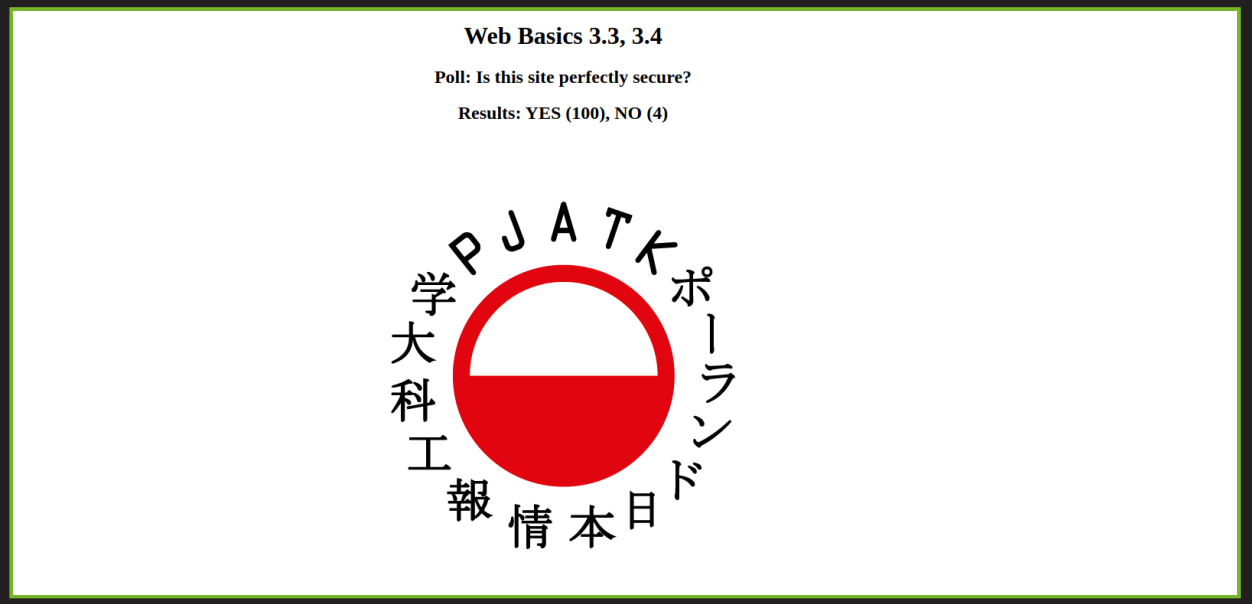
4. Przejdź do zakładki Repeater i zagłosuj 3 razy na NIE, korzystając z przycisku Send.



Zadanie 3.3: Burp Suite Repeater

Celem zadania jest zapoznanie studenta z funkcjonalnością Repeater w programie Burp Suite.

5. Zagłosuj 3 razy na NIE.







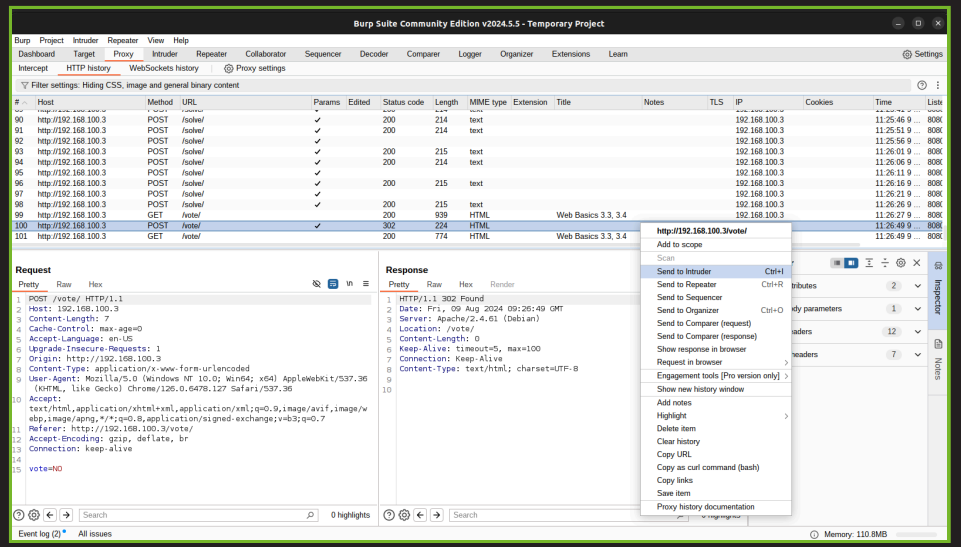
Zadanie 3.4: Burp Suite Intruder

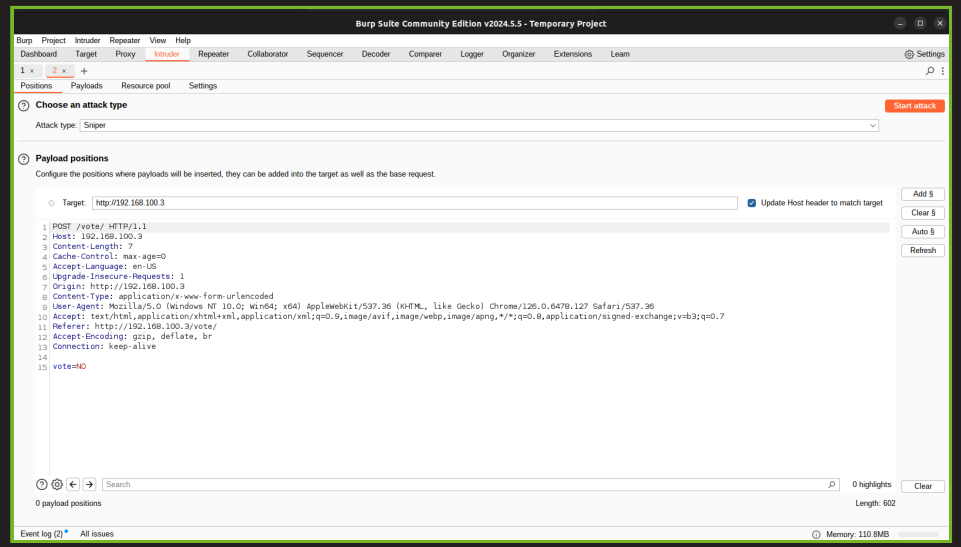
Zakładka **Intruder** w Burp Suite służy do automatycznego przeprowadzania testów bezpieczeństwa aplikacji webowych. Umożliwia wysyłanie serii zmodyfikowanych żądań HTTP, co jest przydatne do testowania różnych typów ataków, takich jak SQL injection, brute force czy fuzzing. Użytkownik może skonfigurować różne parametry, takie jak zakresy wartości, które mają być wstrzykiwane w żądania. Intruder analizuje odpowiedzi serwera, pomagając wykryć podatności lub nieprawidłowości. To potężne narzędzie automatyzacji jest niezbędne w procesie kompleksowej oceny bezpieczeństwa aplikacji webowych.

Zadanie 3.4: Burp Suite Intruder

Celem zadania jest zapoznanie studenta z funkcjonalnością Intruder w programie Burp Suite. Zadanie zostanie zaliczone, gdy w ankiecie wygra opcja „NIE” (ponad 100 głosów). Za pomocą Intrudera możemy zautomatyzować wysyłanie zapytań w dużej ilości.

1. Wyślij do Intrudera zapytanie głosujące na „NIE”. Można to zrobić z poziomu historii HTTP lub Repeatera.

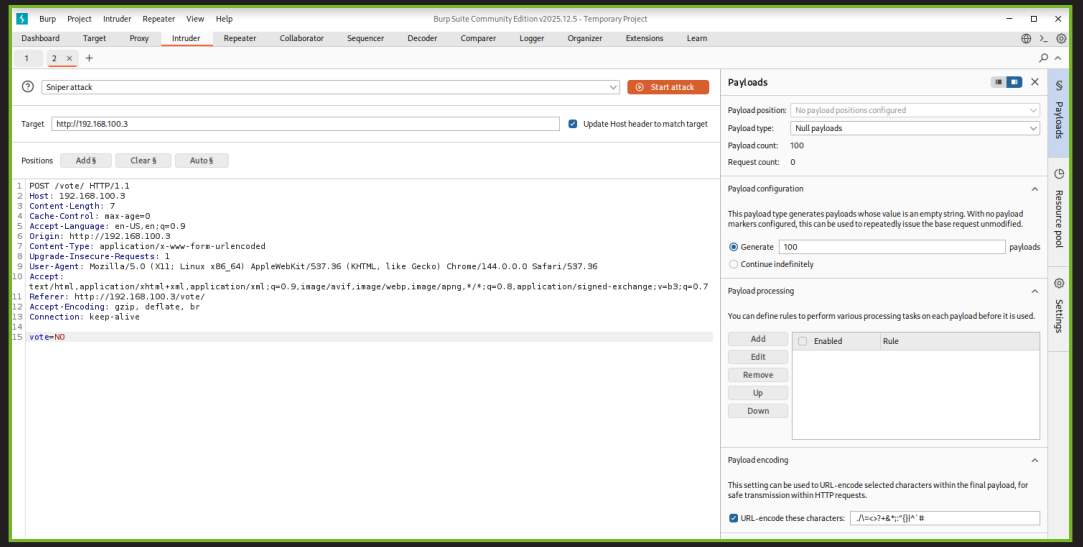




Zadanie 3.4: Burp Suite Intruder

Celem zadania jest zapoznanie studenta z funkcjonalnością Intruder w programie Burp Suite.

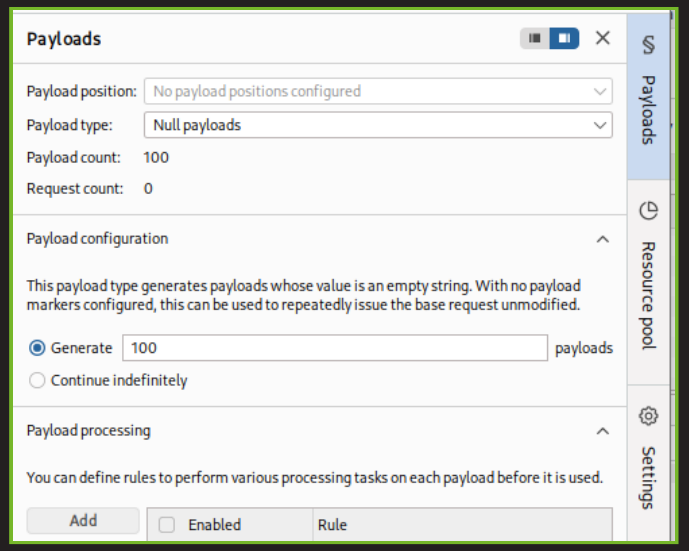
2. Wyczyść miejsca payloadów (opcja Clear §).
3. Ustaw payload type na Null payloads (oznacza to, że Burp nie będzie modyfikował oryginalnego zapytania).

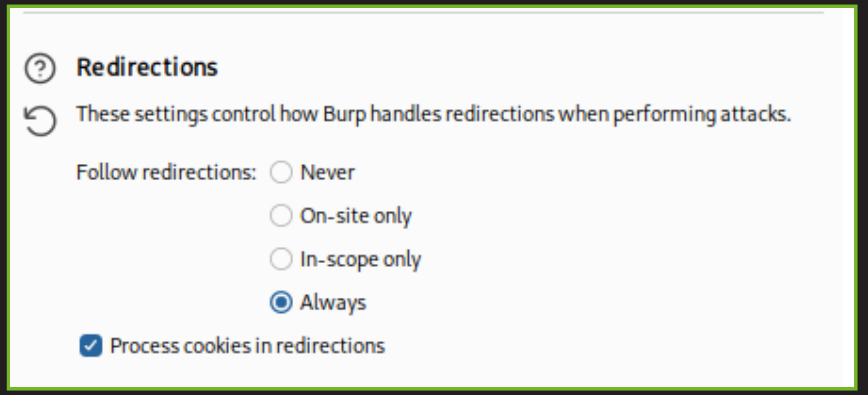


Zadanie 3.4: Burp Suite Intruder

Celem zadania jest zapoznanie studenta z funkcjonalnością Intruder w programie Burp Suite.

4. Ustaw liczbę wygenerowanych payloadów na ponad 100, a w menu settings skonfiguruj przekierowania jak na screenshocie. Uwaga, w niektórych wersjach Burp może to wyglądać nieco inaczej.

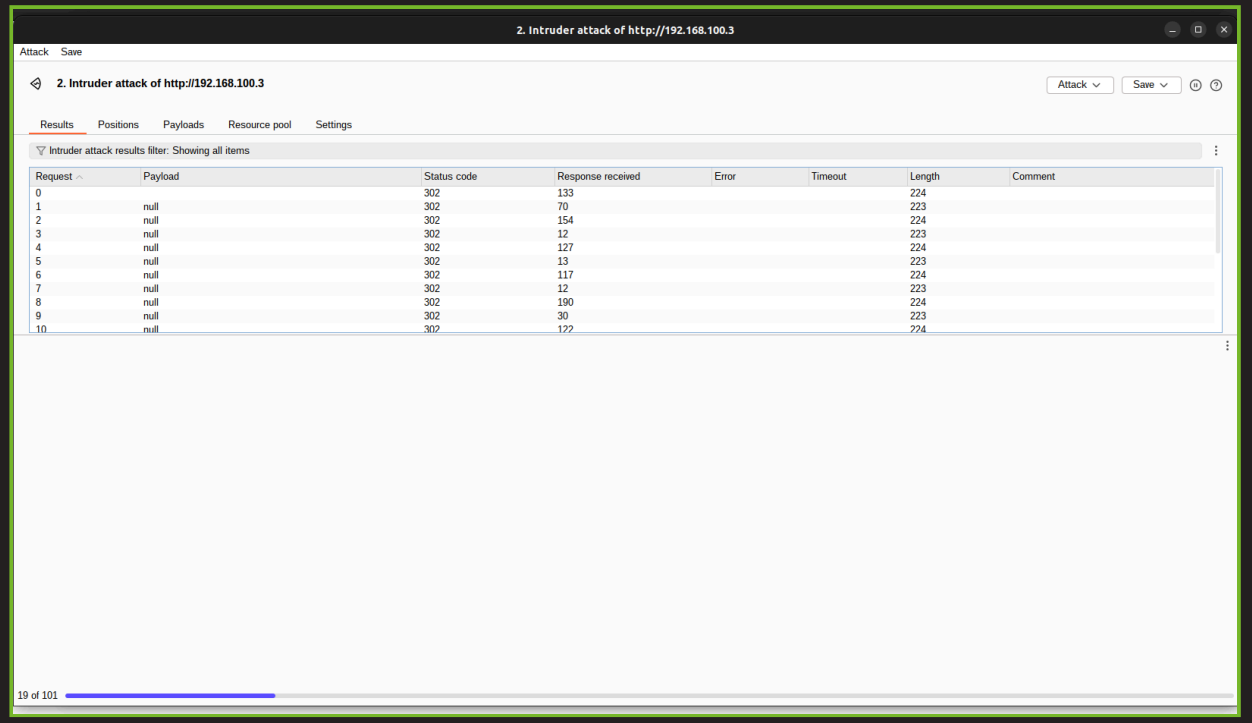


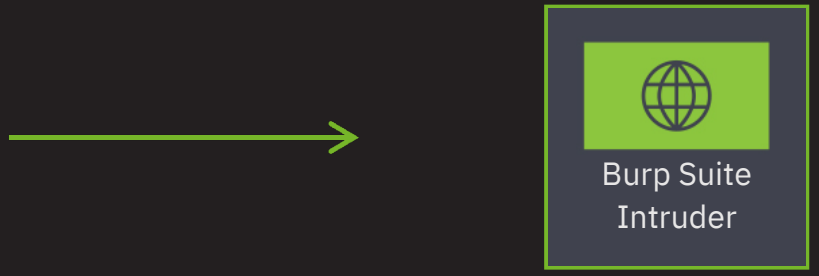


Zadanie 3.4: Burp Suite Intruder

Celem zadania jest zapoznanie studenta z funkcjonalnością Intruder w programie Burp Suite.

5. Uruchom atak.





Zadanie 3.5: Burp Suite Decoder

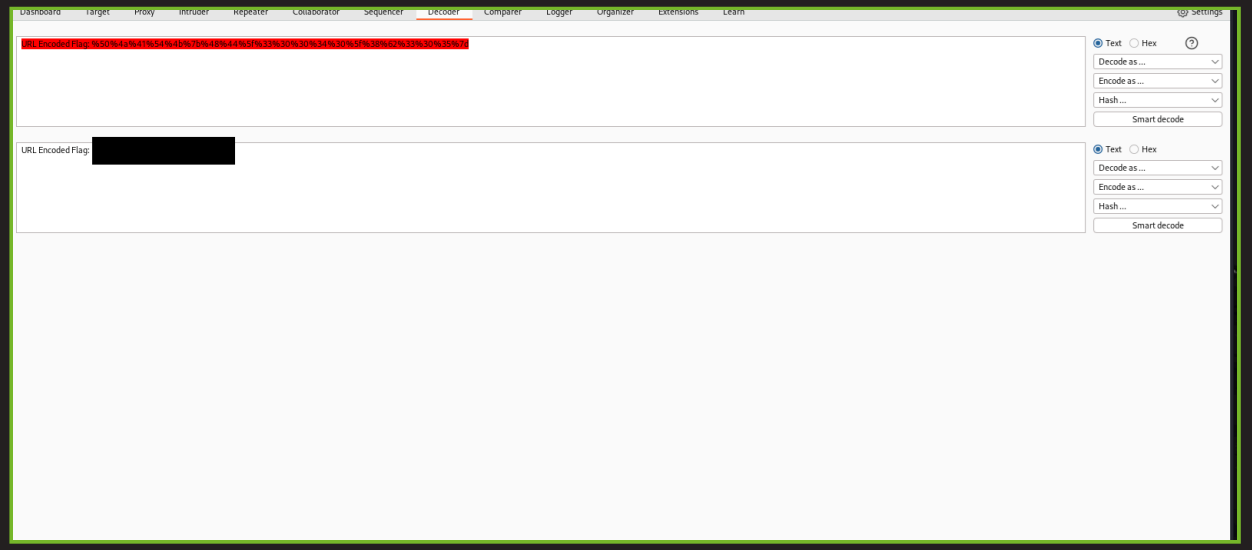
Zakładka **Decoder** w Burp Suite służy do dekodowania i kodowania danych, co ułatwia analizę i manipulację różnymi formatami informacji. Użytkownik może wprowadzać dane w różnych formatach, takich jak Base64, URL encoding, czy hex, i przekształcać je w czytelny tekst lub odwrotnie. Decoder jest przydatny do analizy i rozkodowywania zaszyfrowanych lub zakodowanych danych, a także do testowania aplikacji pod kątem prawidłowego przetwarzania danych wejściowych. Umożliwia również konwersję danych między różnymi formatami, co wspomaga proces debugowania i testowania aplikacji webowych.

Zadanie 3.5: Burp Suite Decoder

Celem zadania jest zapoznanie studenta z funkcjonalnością Decoder w programie Burp Suite.

1. Wejdź na stronę http://192.168.100.3/encoded/, gdzie wyświetli się zakodowana flaga.
2. Wykorzystaj moduł Decoder, aby odkodować flagę.
3. Wklej flagę na platformie.

Zadanie 3.5: Burp Suite Decoder







Referencje

- Dokumentacja Burp: https://portswigger.net/burp/documentation
- Podstawy Burp: https://portswigger.net/burp/documentation/desktop/getting-started
- Omówienie funkcji Burp Suite [EN]: https://www.youtube.com/playlist?list=PLoX0sUafNGbH9bmbIANk3D50FNUmuJIF3
- Konfiguracja proxy, aby używać Burp w dowolnej przeglądarce: https://www.youtube.com/watch?v=2FazeN1tb50